- Tiers : Il faut déterminer par quel fournisseur tiers notre client obtient des services Cloud FAI ou autres notre client doit recevoir le consentement écrit de ces fournisseurs. Déclarant qu'il accepte et sont conscient que certaine parties de leur infrastructure seront soumis a des "piratage simulés".

- Risques : Nous avons l'obligation d'informer le client des risques liés au test et ses conséquences possibles et en fonctions de ceux-ci prendre des limites et fixer des précautions. ⚠ Il faut également déterminer quels composant sont essentiels au bon fonctionnement du client et ne pas les influencer davantages car ils pourrait entrainer des erreurs critiques.

- Coordonnées : Pour les coordonnés nous devons créé une liste avec le nom le titre le post, l'adresse mail le numéro de téléphone, le numéro professionnel un ordre de priorité pour l'escalade de chaque personnes.

- Cannaux de communications : Il convient de documenter les cannaux de communication utilisés pour échanger les informations entre le client et nous. (correspondance email, appel téléphonique, reunion en personne.

- rapports : Outre la structure classique du rapport, toutes les exigences spécifique client que le rapport doit contenir sont également discutées.

- Conditions de paiement : Enfin les prix et conditions de paiments sont expliqués.

Enfin après la signature de tout les documents a lieu la reunion de lancement. ⚠ Si le test physique accompagne le projet/commande un contrat de prestation supplémentaire est requis.



Getting Start

Catégorie : Général
Difficulté : Fondamental, Tier 0
Durée Estimée : 8 Heures

Démarrer avec une distribution de Pentest.

En tant que pentester nous devons comprendre, savoir maintenir, configurer et sécurisé des machines sous Windows et Linux.

Il existe de nombreuses distributions Linux (distros) pour les tests d'intrusion. Un certains nombre sont préchargés avec les outils dont nous avons besoin (Parrot OS, Kali Linux ...) mais beaucoup d'outils nous sont inutiles et d'autres sont manquants. En progressant nous pourrions même créé notre propre VM de pentest personnalisé sur une image de base Debian ou Ubuntu.

Parrot OS est ma distribution préféré et je l'utilise même comme OS principal mais cette configuration n'est pas recommandé pour des questions de stabilité et sécurité si on est amené à tester des infrastructure nous donnant accès à des données sensibles, des configs comme, une VM le dual boot ou multi boot ou Cygwin sont excellentes.

Il est recommandé et même presque obligé d'avoir une VM prête a tourner pour tester ses scripts payloads et pour monter des labs.

- Monter un (Home lab) pour tester des vulnérabilités, tester des applications vulnérable voir des moyens de sécurisation est un excellent moyen de progresser.